

Activity: Security Audit Simulation

Audit Findings

1. Employees use shared logins for client data systems.
 2. There is no security awareness training program in place.
 3. No badge access or physical locks on the server room.
 4. Antivirus is installed, but firewalls are not configured properly.
 5. No system alerts are set up for unusual login activity.
 6. Critical systems have not been patched in over six months.
 7. The company has no documented incident response plan.
 8. Security cameras exist, but footage is never reviewed.
 9. No backup of client data is performed regularly.
 10. MFA is not enabled on email or remote access accounts.
-
1. This needs least privilege, or role-based access. Probably not all employees need full access to client data systems. Access authorization would fall under Administrative, and Preventive. This weakness makes it easier for attackers to target anyone at the company for their credentials, exposing client data.
 2. There needs to be periodic security awareness training to attempt to prevent phishing, or other social engineering attacks. This type of training falls under Administrative, and Preventive. This weakness makes it easier to trick, or coerce an employee to target their credentials to gain access to the system.
 3. The server room is not secure, and is vulnerable to physical attack, or at risk for someone uploading malware, or something else onto the server. Placing locks on servers, and having badge access to server room falls under Administrative, Physical, and Preventive. This is important to ensure that only authorized personnel can access server room, and unauthorized personnel cannot.

4. The firewall needs to be configured properly, and updates to it need to be done on a regular basis. What good is the hardware/software if it is not used properly to prevent cyber attacks. This is a Technical, and Preventive control. Firewalls filter traffic, and one that is not configured, may allow access to anyone into the system.

5. If no alerts are set up for unusual login activity, then the business will not know if, and when an incident might occur. Intrusion detection systems, and log monitoring tools can aid companies in seeing who's trying to gain access to their systems, and can serve as a Technical, and Detective control. If something were to happen, these can aid in finding out what, and if something happened.

6. If critical systems have not been patched in 6 months, then malware, and anti-virus scans should happen immediately. Patches should also be implemented, unless there is already malware, or some other infection to the system. Patching the system falls under Technical and Corrective controls. Without keeping up with patches, the system becomes vulnerable to things that the patch might have fixed.

7. If the company has no incident response plan, then they are unprepared for many threat vectors. These can include DoS, malware, and others. Plans should be in place for back-ups, incident response, There should be plans laying out company, and employee responsibilities in a given situation, otherwise there is chaos, and the situation could be made worse.

8. If security cameras exist, and they are not reviewed, then the company has no idea if a physical breach could have happened. Cameras should be reviewed on a periodic basis, and the company would probably be best served to have actual security guards, if they don't already, and have those personnel responsible for that, and also have procedures for reporting suspicious activity noted from camera footage. Implementing this is an example of Physical, and Detective controls.

9. Not having backups of client data is problematic, because if data is compromised, company could lose all of it, or it could be used against clients. Periodic backups are a necessary part of ensuring that if something does happen, then at least you can restore from a known good backup from a given point, and not lose all data. Implement a schedule for backing up systems. This is an example of Technical, and Corrective controls.

10. MFA not being enabled on email or remote access accounts is a problem because MFA is like another layer of security beyond just a password. A password can become compromised, multi-factor authentication ensures that even if a password becomes compromised, that there are still other controls in place to minimize the chance that an attacker can access the account. Using things such as one-time passcodes, or bio-metrics strengthens security for clients, and company. MFA being used is an example of Technical, and Preventive controls.